[文章标题]

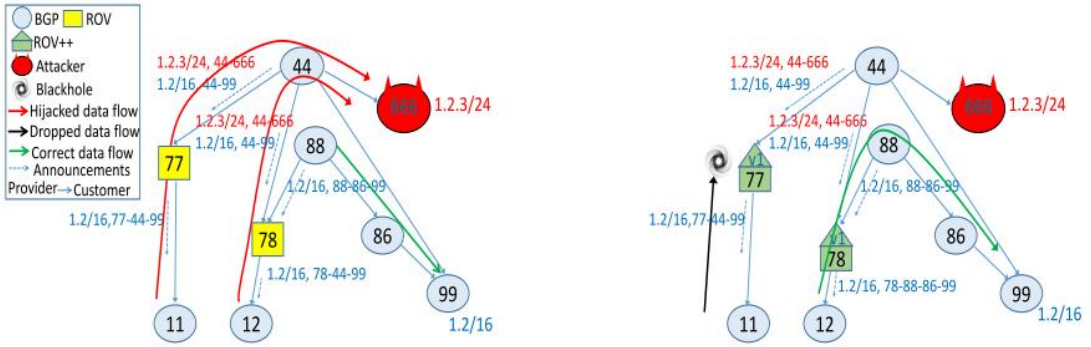
ROV++: Improved Deployable Defense against BGP Hijacking

——2021 NDSS

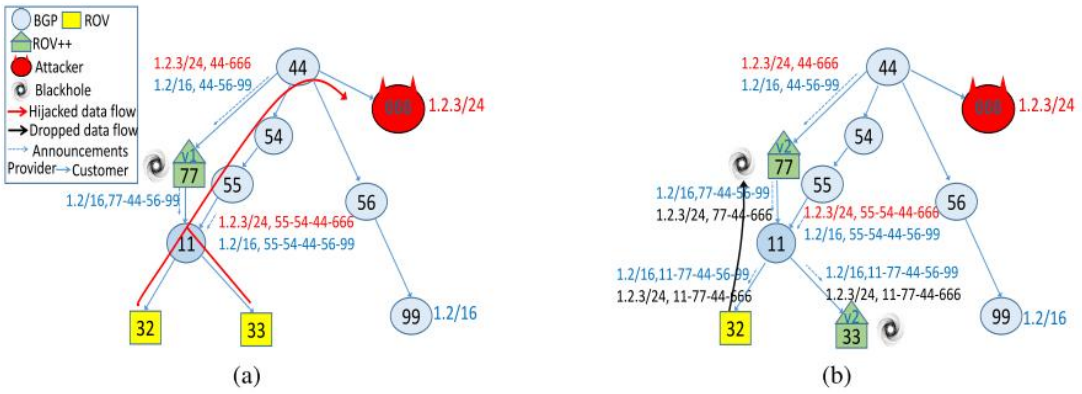
[概要]

边界网关协议(BGP)是互联网的核心域间路由协议，但是由于设计之初未包含认证机制，这一缺陷使其长期面临着路由劫持攻击的风险，特别是子前缀劫持(subprefix hijacks)和未路由前缀劫持(non-routed prefix hijacks)。对此，标准化的防御机制是路由源验证(Route Origin Validation, ROV)。然而，本论文指出，在部署不完全的情况下，ROV 对这些主要攻击的防护效果有限，尤其是子前缀劫持。此外，ROV 还会引发隐藏劫持，即路由表路径正确，但实际数据流却被劫持的现象。

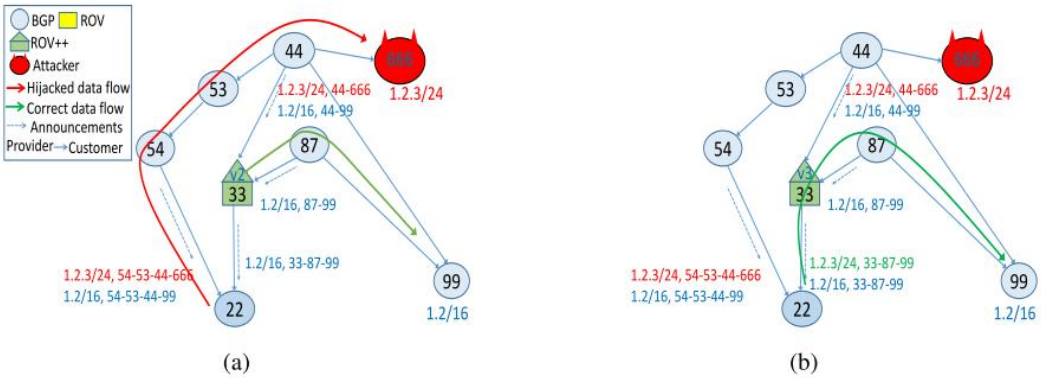
为了解决 ROV 在部分部署的场景下安全防护效果不足的问题，本文提出并设计了增强型防御机制 ROV++，其中包含三个逐步增强的变体 v1/v2/v3 及若干 Lite 软件化实现，其基本思路是在保留 ROV 验证的同时增加三个核心机制：



（1）v1:是通过检测路由“空洞”（Hole）实现，即当来自同一邻居的合法前缀公告与无效子前缀公告并存时，意味着经由该邻居的对应子前缀流量将被劫持。v1 将优先选择无空洞的安全路径；若不存在此类路径，则对受影响子前缀执行黑洞处理，从而彻底避免流量被攻击者窃听或中转。

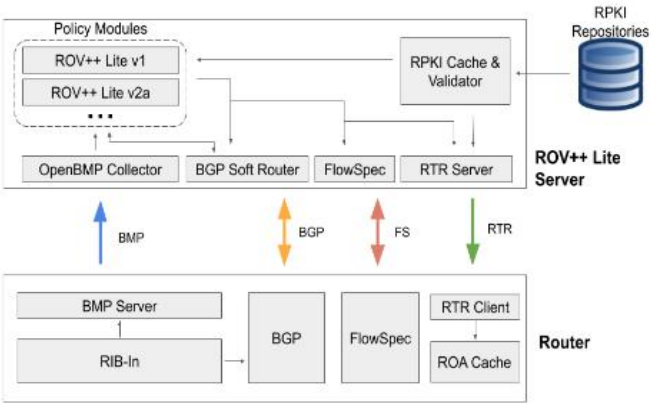


（2）v2:在 v1 基础上，当本地黑洞不足以保护下游时，向下游发出黑洞公告，把流量吸引到能被安全丢弃的位置，保护它们免受劫持。



（3）v3：在 v2 基础上，v3 会主动发出预防性公告，用合法路径信息与攻击的子前缀竞争，尝试将流量引导至合法源，以提升成功到达合法源的概率。

本文实现了一个 BGP 仿真器，并使用 2020 年 CAIDA 的 AS 拓扑数据，做了 2000+次的大规模模拟。在此基础上，论文进一步提出了 ROV++的 Lite 版本，一种纯软件方案，可以基于现有路由器上的标准机制部署，大幅降低了部署门槛。



文章还进行了进一步的分析和实验测试，结果表明：

（1）在 5%采用率的情况下，采用 ROV 的边缘 AS 中约 95%仍会遭受子前缀劫持，而采用 ROV++的边缘 AS 中只有 5%遭受劫持。证明 ROV++对边缘 AS 都有显著的安全防护效果。

（2）在面对非路由前缀的超前缀攻击时，ROV++通过其黑洞机制能够实现完全防御，而 ROV 无法阻止此类攻击。

（3）ROV++的 Lite 版本在性能上与其非 Lite 版本几乎相同，进一步验证了该方案的实用价值。

[优点]

- 论文明确指出 BGP 安全协议中的路由源验证机制在部分部署这一场景下存在安全防护效果递减的问题。
- ROV++机制增强了对传统的子前缀劫持的防御效果，实现了对未路由前缀劫持以及新发现的超前缀劫持的有效防护，即使在部署率较低的情况下，仍有显著的安全防护效果。
- 提出了实用性强的 ROV++ Lite 版本，兼容现有路由器，实现了纯软件的部署方式，降低了部署门槛。

[缺点]

- 本文中的假设偏理想化，如完全遵循谷自由路由、无 ROA 配置错误等，与现实情况不符，在实际场景下 ROV++的效果仍需进一步验证。
- ROV++ v1 和 v2 在没有安全路径时采用黑洞处理，虽然避免了流量被攻击者劫持，但也牺牲了部分网络的可达性。
- 虽然 ROV++显著降低了劫持率，但仍然存在隐藏劫持的现象，这表明 BGP 控制平面与数据平面不一致的问题并未被彻底消除。

[评论]

本文属于路由安全与防御机制类研究，文章内容扎实、分析细致，从现实的角度出发，重新思考路由安全机制。针对 BGP 安全协议在部分部署这一现实情况下的局限性，作者并未沿用传统 RPKI ROV 的研究思路，而是将设计重心巧妙地放在 ROV 低采用率下仍能显著提升安全效益上，以此来设计增强型防御机制。

本文并未采用复杂的加密扩展，而是通过一系列可逐步部署的增强策略实现防御能力的渐进提升。尤其是基于 hole 检测与 blackhole 策略，路由器能够在本地自主判断是否存在被劫持风险，并在必要时主动丢弃可疑流量或发布黑洞公告，从而在不改变现有架构的前提下提升安全性。

个人认为这是在 BGP 安全领域最贴近实际应用场景的方案之一，其写作逻辑、实验严谨性、以及对部署现实的考量都值得参考。但仍存在一些考虑不周之处：首先并没有量化黑洞机制带来的可用性问题，部分情况下可能导致丢弃合法流量；此外，预防性公告 v3 存在被滥用的潜在风险，没有签名机制可能会与未来的 BGPsec 冲突。上述这些问题虽不影响论文的主要贡献，但是无论是后续的研究还是实际部署都需要进一步考虑上述不足。

总而言之，本文不仅是对 ROV 机制的重要改进，更是为未来互联网路由安全的研究与实践提供了有价值的思路和工具。但其中涉及的黑洞与预防公告在提升安全性的同时，也可能带来的网络可达性下降与潜在滥用风险，这些问题仍需进一步的研究验证。